

Chase Bank Impersonation

Ticket Overview

Ticket Number: SOC-14991

Date/Time Reported: 2024-05-02 / 08:24:21 UTC

Assigned Analyst: Jeremiah Tindana

Affected Endpoint : N/A

Affected User: Bob Sanders

NB: The sample phishing email analyzed in this report ([sample1.eml](#)) is training material from TCM Security's SOC curriculum. All investigation, IOC extraction, and analysis in this report — including the header review, IOC classification, and MITRE ATT&CK mapping — is my own independent work, not the course's own walkthrough or answer key. The company name and ticket number are fictional and used for realistic case-report formatting.

Incident Summary

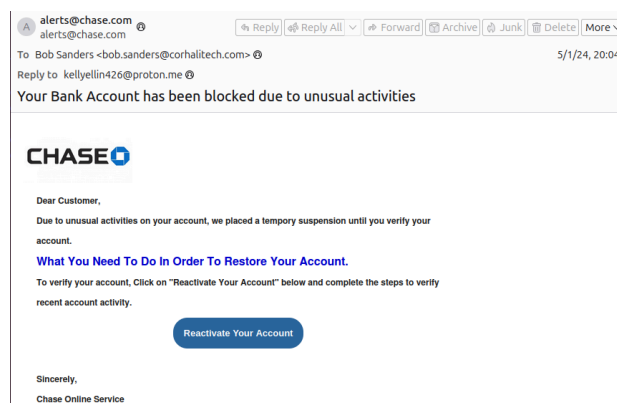
On **May 2, 2024 at 8:24:21 AM**, Corhali Tech executive Bob Sanders ([bob.sanders@corhalitech\[.\]com](mailto:bob.sanders@corhalitech[.]com)) reported receiving an email that seemed to suggest that his account at Chase bank had been suspended. Bob was alarmed, because he does have an account with Chase Bank. However, he was still able to access his account from his mobile banking app. Also, Bob wondered why he was receiving banking alerts on his company email address. Bob reported the email to the SOC after clicking the link that was provided in the email. He informed the SOC that he tried signing in using the link, but was faced with an error. The incident response team provided the SOC analysts with the email file for further investigation.

Investigation

I began my investigation with a high level view of the available cues. I searched for common phishing techniques such as pretexting, spoofing and URL manipulation, and strategies such as intimidation, urgency or FOMO. The email was informing Bob Sanders that his account had been blocked due to suspicious activity, and provided a link through which he would verify and reactivate his account. This is a common intimidation tactic used by malicious actors in an attack. I opened the email file using Thunderbird.

```
tcmsoc201:~/Desktop/101_course_files/01_Phishing_Analysis/01_Header_Analysis$ thunderbird sample1.eml
Gtk-Messag: 16:53:55.672: Not loading module "atk-bridge": The functionality is provided by GTK natively
. Please try to not load it.
[GFX1-]: glxtest: libpci missing
JavaScript warning: https://transcend-cdn.com/cn/d556c3a1-e57c-4bdf-a490-390a1aebf6dd/airgap.js, line 5:
Script terminated by timeout at:
uu@https://transcend-cdn.com/cn/d556c3a1-e57c-4bdf-a490-390a1aebf6dd/airgap.js:5:3696
ke@https://transcend-cdn.com/cn/d556c3a1-e57c-4bdf-a490-390a1aebf6dd/airgap.js:5:4462
Op/<https://transcend-cdn.com/cn/d556c3a1-e57c-4bdf-a490-390a1aebf6dd/airgap.js:5:16514
Md@https://transcend-cdn.com/cn/d556c3a1-e57c-4bdf-a490-390a1aebf6dd/airgap.js:10:6378
I_@https://transcend-cdn.com/cn/d556c3a1-e57c-4bdf-a490-390a1aebf6dd/airgap.js:10:5651
```

Picture 1. Thunderbird command to open email file.



Picture 2. Email file open with Thunderbird

```
es/01_Phishing_Analysis/01_Header_Analysis$ subl sample1.eml
es/01_Phishing_Analysis/01_Header_Analysis$
```

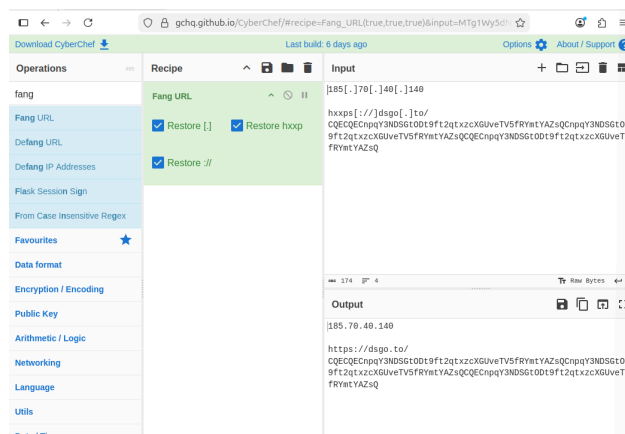
Picture 3. Command to open email file with Sublime text.

```
6 Microsoft SMTP Server (version=TLS1 2,
7 cipher=TLS ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.7519.34; Wed, 1 May
8 2024 20:04:14 +0000
9 Received: from SA2PEPF00001509.namprd04.prod.outlook.com
10 (2603:10a6:102:37d:cafe::c1) by PA7P264CA0421.outlook.office365.com
11 (2603:10a6:102:37d:22) with Microsoft SMTP Server (version=TLS1 2,
12 cipher=TLS ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.7544.25 via Frontend
13 Transport; Wed, 1 May 2024 20:04:13 +0000
14 Authentication-Results: spf=pass (sender IP is 185.70.40.140)
15 smtp.mailfrom=protonmail.com; dkim=timeout (key query timeout)
16 header.d=protonmail.com; dmarc=pass action=none
17 header.from=protonmail.com; compauth=pass reason=100
18 Received-SPF: Pass (protection.outlook.com: domain of protonmail.com
19 designates 185.70.40.140 as permitted sender)
20 receiver=protection.outlook.com; client-ip=185.70.40.140;
21 helo=mail-40140.protonmail.ch; pr=C
22 Received: from mail-40140.protonmail.ch (185.70.40.140) by
23 SA2PEPF00001509.mail.protection.outlook.com (10.167.242.41) with Microsoft
24 SMTP Server (version=TLS1 3, cipher=TLS AES_256_GCM_SHA384) id 15.20.7544.18
25 via Frontend Transport; Wed, 1 May 2024 20:04:11 +0000
26 X-IncomingTopHeaderMarker:
27 OriginalChecksum:C17AD509B4FA1C3AD6837AF53B05160C3206DAEA597C784A116FBD1E13
28 D3CAA;UpperCasedChecksum:255DA5C4E53258A65E29BCEB32930DEF55AEEE0D3B9737CDFDD
29 A32BCDD0F73A9;SizeAsReceived:1160;Count:10
30 From: alerts@chase.com
31 Date: Wed, 01 May 2024 20:04:05 +0000
32 Message-ID: <17g9MMh5NtErta0zQZEp3D-i-u3FWwdo0wY5mhD8Q1vIvVlyeLj-jMWPAn-HP3Fu
33 gKsucsWSub06Vns8GRFY0aH4MyU2paqPoyUnRcgaU=@protonmail.com>
34 X-Pm-Message-ID: 55310a2549b19d9ae8e8c9d77c7f7bf967e0fa21
35 Subject: Your Bank Account has been blocked due to unusual activities
36 To: Bob Sanders <bob.sanders@corhalitech.com>
37 Reply-To: kellyellin426@proton.me
38 Return-Path: kellyellin426@proton.me
39 X-MS-Exchange-Organization-ExpirationStartTime: 01 May 2024 20:04:11.6382
40 (UTC)
41 X-MS-Exchange-Organization-ExpirationStartTimeReason: OriginalSubmit
42 X-MS-Exchange-Organization-ExpirationInterval: 1:00:00:00.0000000
43 X-MS-Exchange-Organization-ExpirationIntervalReason: OriginalSubmit
44 X-MS-Exchange-Organization-Message-Id:
45 1379135b-f2fa-4380-9202-08dc6a19de51
46 X-EOPAttributedMessage: 0
47 X-EOPTenantAttributedMessage: 84df9e7f-e9f6-40af-b435-aaaaaaaaaaaa:0
48 X-MS-Exchange-Organization-MessageDirectionality: Incoming
49 X-MS-PublicTrafficType: Email
50 X-MS-Exchange-Organization-AuthSource:
51 SA2PEPF00001509.namprd04.prod.outlook.com
52 X-MS-Exchange-Organization-AuthAs: Anonymous
53 X-Sender-IP: 185.70.40.140
54 X-MS-Exchange-Organization-PCL: 2
55 X-MS-Exchange-Organization-AuthAs: Anonymous
```

Picture 4. Email file open with sublime text editor to reveal headers.

I saved the email in a text file for a deeper examination. I examined the sender's details including the "From" and "Reply-To" and "Return-Path" fields. The From field contained "alerts@chase.com". The Reply-To and Return-Path fields both contained a disturbing email address **kellyellin426@proton[.]me**. It is unsettling that an email received from Chase Bank would accept replies on a separate private email address that typically does not require any user identity verification. A legitimate Chase email will never route replies to a random proton[.]me address.

Using the **eioc[.]py** tool, I extracted the sender's ip address and the link that was provided in the email. Because this tool provides the IOCs in defanged format, I fanged them using CyberChef to make analysis possible.



Picture 5. Fanging URL and IP address using Cyberchef

```

tcn@SOC201:~/Desktop/101_course_files/01_Phishing_Analysis/01_Header_Analysis$ python3 ../Tools/eioc.py
sample1.eml
Extracted IP Addresses:
=====
185[.]70[.]40[.]140 - Plan-Les-Ouates, Geneva, CH, ISP: AS62371 Proton AG
18[.]167[.]242[.]41

Extracted URLs:
=====
hxxps[://]raw[.]githubusercontent[.]com/MalwareCube/SOC101/main/assets/01_Phishing_Analysis/34c8f34e-64
a8-4ad7-874a-a9b70ee648e2_0_0_0_0_0_0[.]jpg
hxxps[://]dsgof[.]to/CQECQECnpqY3NDSgt0Dt9ft2qtzxcXGUveTV5fRYmtYAZsQCnpqY3NDSgt0Dt9ft2qtzxcXGUveTV5fRYmt
YAZsQCQECnpqY3NDSgt0Dt9ft2qtzxcXGUveTV5fRYmtYAZsQ

Extracted Headers:
=====
Authentication-Results: spf=pass (sender IP is 185.70.40.140)
                        smtp.mailfrom=protonmail.com; dkim=timeout (key query timeout)
                        header.d=protonmail.com; dmarc=pass action=none
                        header.from=protonmail.com; compauth=pass reason=100
From: alerts@chase.com
Date: Wed, 01 May 2024 20:04:05 +0000
Message-ID: <17g9MHSNtErtazQZEp3D-l-u3FWdo8wY5nhD8Q1v1v1yElj-jMMPAn-HP3FugKsuesh5Sub0BVns8GRFYG0ah4
MyU2paqP6yUnRcgaU=@protonmail.com>
Subject: Your Bank Account has been blocked due to unusual activities
To: Bob Sanders <bob.sanders@corhalltech.com>
Reply-To: kellyellin426@proton.me
Return-Path: kellyellin426@proton.me
X-Sender-IP: 185.70.40.140

Extracted Attachments:
=====

```

Picture 6. IOCs extracted from email file using eioc[.]py

The extraction also returned a second URL pointing to a `raw[.]githubusercontent[.]com` asset. This is a static image hosted by the TCM Security training platform to render this exercise and is unrelated to the phishing infrastructure; it has been excluded from the IOC list.

The extraction also returned a second IP, `10.167.242.41`. This is a private (RFC1918) address belonging to Microsoft's internal mail-routing infrastructure, visible because the message transited Office 365 before delivery. It is not part of the phishing infrastructure, and excluded from the IOC list below.

It is also worth observing that the email passed SPF and DMARC checks. DKIM checks showed a timeout. DMARC runs on either SPF or DKIM and not both. That means that this DMARC pass is riding on SPF check alone, which is very easily spoofed.

A whois lookup of the IP address revealed no relationship whatsoever to chase bank.

IP Information for 185.70.40.140

— Quick Stats

IP Location	🇨🇭 Switzerland Plan-les-ouates Proton Technologies Ag
ASN	🇨🇭 AS62371 PROTON Proton AG, CH (registered Nov 17, 2015)
Resolve Host	185-70-40-140.protonmail.ch
Whois Server	whois.ripe.net
IP Address	185.70.40.140

```

% Abuse contact for '185.70.40.0 - 185.70.40.255' is 'abuse@protonmail.ch'

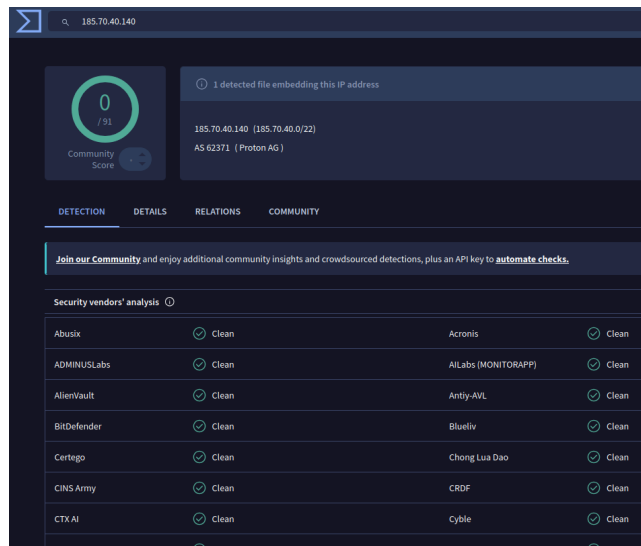
inetnum:        185.70.40.0 - 185.70.40.255
netname:        protonmail-1
descr:          Proton Technologies AG
country:        ch
admin-c:        PLA68-RIPE
tech-c:         NA7583-RIPE
status:         ASSIGNED PA
mnt-by:         protonmail-mnt
mnt-routes:     protonmail-mnt
created:        2014-09-16T08:07:21Z
last-modified:  2024-07-31T12:58:35Z
source:         RIPE

role:           Proton NOC
address:        Route de la Galaise 32
address:        1228 Plan-les-Ouates
address:        Switzerland
phone:          +41 22 884 11 00
e-mail:         noc@proton.ch
admin-c:        JH31332-RIPE
tech-c:         JH31332-RIPE

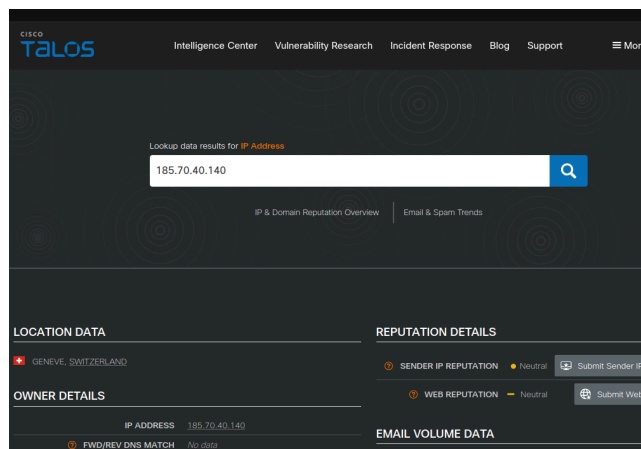
```

Picture 7. Sender's IP address lookup on Whois Domain Tools.

I proceeded to lookup the sender's IP on known malware databases including VirusTotal and CiscoTalos.



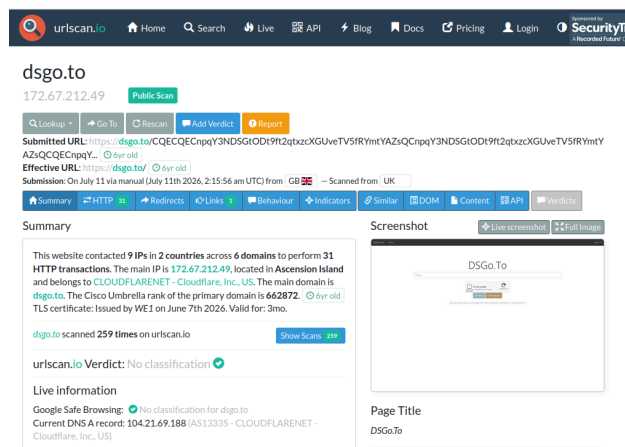
Picture 8. IP Address lookup on VirusTotal



Picture 9. IP Address lookup on CiscoTalos

IP address lookups on these 2 platforms revealed no recorded or reported malicious activities involving this IP address.

I went a step further to examine the URL that was attached to the email and subjected it to reputation checks. URL reputation checks on VirusTotal, CiscoTalos and urlscan[.]io also revealed no reported malicious activities.



Picture 10. urlscan results



Picture 11. Live screenshot from urlscan

Verdict

After going through everything, I'm confident this email is a phishing attempt and not a legitimate message from Chase Bank.

MITRE ATT&CK Mapping

- **Initial Access — T1566.002 (Phishing: Spearphishing Link):** The email delivered a malicious link disguised as an urgent account-verification request, possibly intended to route the victim into a credential-harvesting flow.
- **Impersonation:** The email spoofed a trusted brand (Chase Bank) and routed replies to an unrelated address to sustain the deception. This maps to Impersonation (T1656) as defined in ATT&CK v14–v18; in v19 this behavior was folded into the broader Social Engineering in Stealth (T1684) technique.

The IP and URL reputation checks came back clean across WHOIS, VirusTotal, Talos, and urlscan, but I'm not reading that as a good sign. New phishing infrastructure almost never has a track record yet, so a clean result just means it hasn't been reported or flagged yet, not that it's safe.

The rest of the story lines up too. Bob got a banking alert on his work email instead of a personal one, which doesn't make sense for a real Chase notification. He was also able to log into his actual Chase account through the mobile app with no issues, and when he tried the link in the email, he got an error signing in. That's consistent with a credential harvesting page, not a real banking portal.

The link in the email led to the homepage of a URL shortening service (dsgo[.]to). This tells me the link in the email was almost certainly a shortened URL, and what I captured in the scan is the shortener's own landing page rather than whatever the short link was actually pointing to. That could mean the specific short link had expired, been deactivated, or was already taken down by the time I ran the scan — but I can't confirm what Bob actually saw when he clicked it on May 2. I'm treating this as a gap in the investigation rather than a finding: I don't have confirmation of what the final destination page looked like at the time of the click, and I shouldn't guess that it was a credential harvesting form. Regardless of what the shortened link ultimately resolved to, the spoofing/reply-to evidence alone is sufficient to classify this as phishing.

Indicators of Compromise (IOCs)

IP Address: 185[.]70[.]40[.]140

URL:

hxxps[://]dsgo[.]to/CQECQECnpqY3NDSGtODt9ft2qtxzcXGUveTV5fRYmtYAZsQCnpqY3NDSGtODt9ft2qtxzcXGUveTV5fRYmtYA

Recommendations

1. Block the sender IP, and the URL.
2. Find out whether Bob actually entered his real Chase credentials before hitting that error, because if he did, those need to be treated as compromised and reset right away.
3. I also want to check if anyone else at Corhali Tech got the same email, so we know if this was targeted at Bob specifically or sent out more broadly.

